LAB & FINDINGS REPORT

OWASP Juice Shop

Directory Enumeration and File Exposure Review

Target: http://127.0.0.1:3000
Environment: Kali Linux in Oracle VirtualBox
Assessment: Authorized local training lab
Date: 23 October 2026
Prepared by: Ella Faith M. Sigue

1. Executive Summary

This report documents a focused reconnaissance and file-exposure review of a local OWASP Juice Shop instance. Gobuster was used to enumerate common web paths, then selected paths were manually checked in a browser or with HTTP requests. The evidence shows a browsable /ftp/ directory, a directly accessible document labeled confidential, a quarantine directory containing malware-themed URL filenames, selected HTTP 403 responses, a verbose error response, and a random nonexistent-looking path returning HTTP 200.

These are observations from an intentionally vulnerable local lab, not evidence of compromise of a real organization. The report avoids treating placeholder document text as verified business information and does not claim that a status code alone proves exploitability.

Key observations

- Directory indexing under /ftp/ reveals filenames and subdirectories that could help identify sensitive artifacts.
- The acquisitions.md file is accessible and explicitly labeled confidential, although its content contains placeholder text.
- The quarantine directory exposes malware-themed .url filenames; no file was downloaded or executed.
- Requests for package.json.bak and suspicious_errors.yml returned HTTP 403, showing those specific requests were blocked.
- The extension-restriction error includes application stack-trace details.
- A random nonexistent-looking path returned HTTP 200, consistent with catch-all or soft-404 behavior.

2. Objectives and Scope

- Enumerate common paths on the local Juice Shop instance.
- Preserve the scan output and capture screenshots of relevant results.
- Validate selected directory listings and HTTP response behavior.
- Document potential information exposure and propose practical remediation.

In scope: http://127.0.0.1:3000 and the paths shown in the evidence. Out of scope: external systems, credential harvesting, malware execution, destructive testing, and claims about real-world compromise.

3. Lab Environment and Tools

Target	http://127.0.0.1:3000
Application	OWASP Juice Shop
Operating system	Kali Linux in Oracle VirtualBox
Enumeration tool	Gobuster v3.8.2
Wordlist	/usr/share/seclists/Discovery/Web-Content/common.txt
Scan settings	5 threads; 15-second timeout; exclude response length 9984
Output file	~/juice-shop-gobuster-seclists.txt

4. Methodology

1. Ran Gobuster against the local target using the SecLists common web-content wordlist.
2. Excluded responses with length 9984 bytes to reduce noise from the application's wildcard response behavior.
3. Saved the completed scan output to a text file for repeatability.

4. Inspected the /ftp/ and /ftp/quarantine/ directory listings in the browser.
5. Sent targeted requests to selected files and a random nonexistent-looking path, recording the visible HTTP status and error response.
6. Compared observations against likely security implications, while distinguishing confirmed behavior from assumptions.

The scan completed at 4,750 / 4,750 entries. HTTP 404 was configured as a negative status. Because a random path returned HTTP 200, the scan results should be interpreted with the application's fallback behavior in mind.

5. Findings

F-01 — Directory listing exposes file inventory

Assessment: Preliminary: Medium

Evidence: The /ftp/ page displays a directory index containing documents, backup-like files, and a quarantine subdirectory.

Security significance: A public listing can disclose filenames and help an attacker locate potentially sensitive artifacts. The listing does not prove every item is retrievable.

Recommended action: Disable directory indexing; remove sensitive artifacts from web-accessible directories; enforce authorization checks on file retrieval.

F-02 — Confidentiality-labeled document accessible

Assessment: Preliminary: Medium

Evidence: GET /ftp/acquisitions.md displays a document with the warning “This document is confidential! Do not distribute!”

Security significance: A document marked confidential is available without an apparent access barrier in the lab. The body contains placeholder text, so its stated business plans are not verified facts.

Recommended action: Move confidential files outside the public web root and require appropriate authentication and authorization.

F-03 — Quarantine directory reveals malware-themed filenames

Assessment: Preliminary: Low–Medium

Evidence: The /ftp/quarantine/ listing shows platform-specific juicy_malware_*.url filenames.

Security significance: The names expose potentially risky artifacts and may encourage unsafe interaction. The files were not downloaded, inspected, or executed.

Recommended action: Prevent public listing; isolate suspicious artifacts; use controlled malware-analysis procedures and least privilege.

F-04 — Selected file requests blocked

Assessment: Observed restriction; not a vulnerability by itself

Evidence: Requests for /ftp/package.json.bak and /ftp/suspicious_errors.yml returned HTTP 403.

Security significance: These specific requests were denied. This does not prove that all sensitive files are protected or that the restrictions are comprehensive.

Recommended action: Retain deny-by-default controls and validate access rules against the full intended file set in the authorized lab.

F-05 — Error response reveals implementation details

Assessment: Preliminary: Low

Evidence: The response for suspicious_errors.yml states that only .md and .pdf files are allowed and includes stack-trace/file-path details.

Security significance: Verbose errors can reveal application structure and implementation details that may help further investigation.

Recommended action: Return generic client-facing errors and retain diagnostic details only in server-side logs.

F-06 — Nonexistent-looking path returns HTTP 200

Assessment: Informational; validate further

Evidence: The path /definitely-not-a-real-path-12345 returned HTTP 200.

Security significance: This may be a catch-all route or soft-404 behavior. The status code alone does not establish that the resource exists or that a vulnerability is present.

Recommended action: Compare response body, headers, and size with known valid and invalid paths; configure scanners to account for fallback responses.

F-07 — Multiple routes return HTTP 500 during enumeration

Assessment: Unverified; investigation recommended

Evidence: Gobuster reported HTTP 500 for several paths, including API-related paths and profile/redirect/rest routes.

Security significance: A server error indicates an internal error response, but does not by itself prove a security vulnerability or explain the root cause.

Recommended action: Reproduce selected requests individually, review application logs if available, and document whether errors expose data or affect security.

6. Enumeration Results

The completed scan reported HTTP 200 for paths including ftp, promotion, robots.txt, security.txt, Video/video; HTTP 301 for assets and media; and HTTP 500 for several application routes. The scan output is useful for discovery, but each result needs context. HTTP 200 means the server returned a successful status, not necessarily that a requested resource exists as intended. HTTP 500 is a server error, not automatically a confirmed vulnerability.

7. Limitations

- This was a focused lab exercise, not a full penetration test or complete Juice Shop challenge run.
- No authentication bypass, credential collection, exploitation, data exfiltration, or malware execution was attempted.
- The contents of announcement_encrypted.md and the listed .url files were not analyzed.
- The HTTP 500 routes were recorded but not individually investigated.
- Severity assessments are preliminary and would require validation against a defined production context.

8. Recommendations

7. Disable directory indexing and avoid storing sensitive or backup artifacts in public web directories.
8. Apply server-side access controls to sensitive files rather than relying solely on file-extension restrictions.
9. Remove confidential documents from deployment packages and verify permissions before release.
10. Replace verbose error pages with generic responses while preserving diagnostic details in server logs.
11. Validate the HTTP 200 fallback behavior using response-body comparison and a known valid route.
12. Investigate HTTP 500 routes separately and record reproducible evidence before drawing conclusions.
13. Do not download or execute malware-themed artifacts as part of this evidence collection.

9. Skills Demonstrated

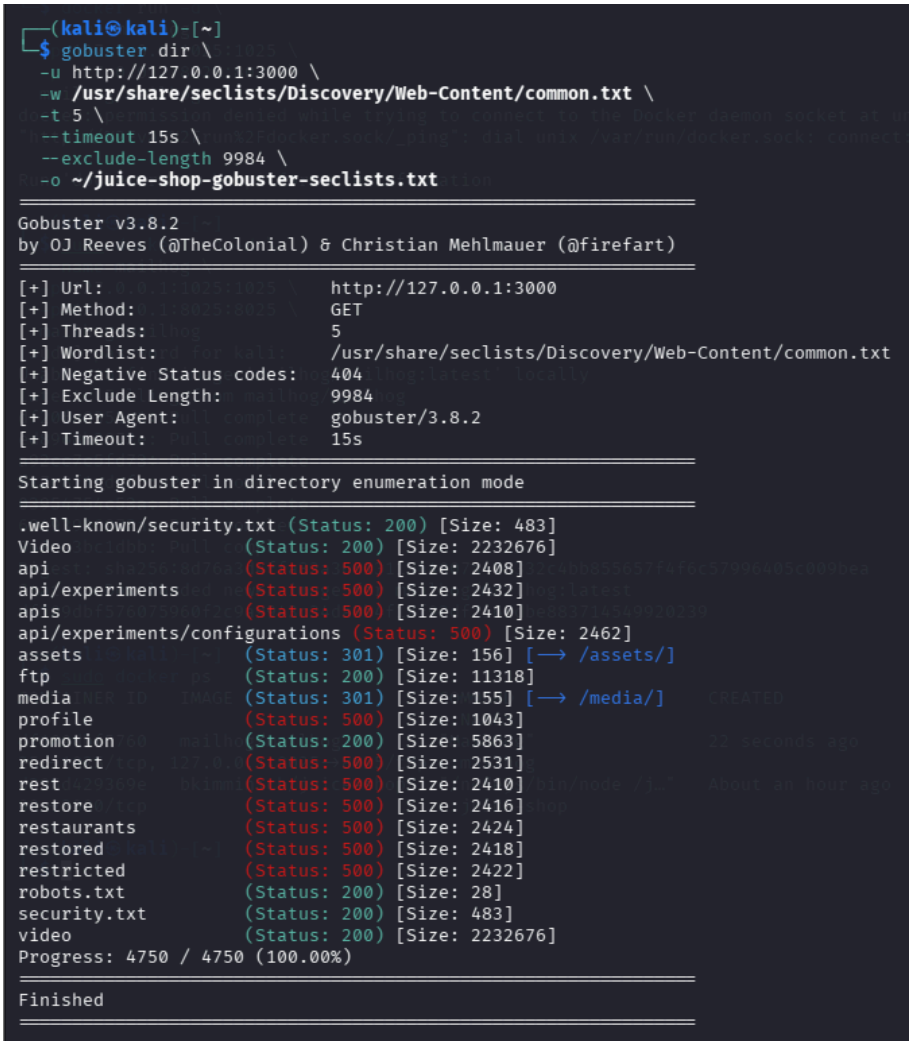
Skills summary: I practiced web content enumeration with Gobuster, HTTP request validation, status-code interpretation, technical evidence collection, and preliminary information-exposure assessment. I also documented limitations, communicated risk without overstating the evidence, and proposed remediation steps within an authorized local lab.

Core skills: web reconnaissance • directory enumeration • HTTP analysis • evidence preservation • risk communication • remediation planning

10. Evidence Gallery

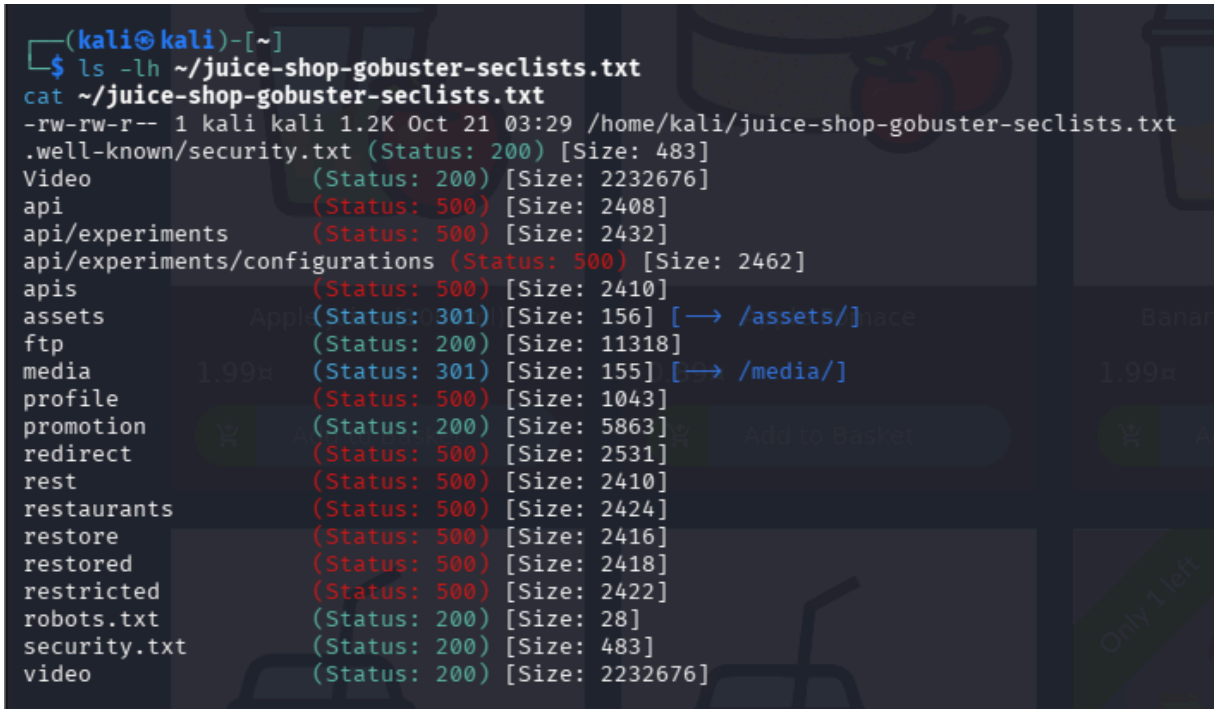
The screenshots below support the observations described in this report. Captions distinguish visible evidence from interpretation.

Figure 1. Completed Gobuster enumeration



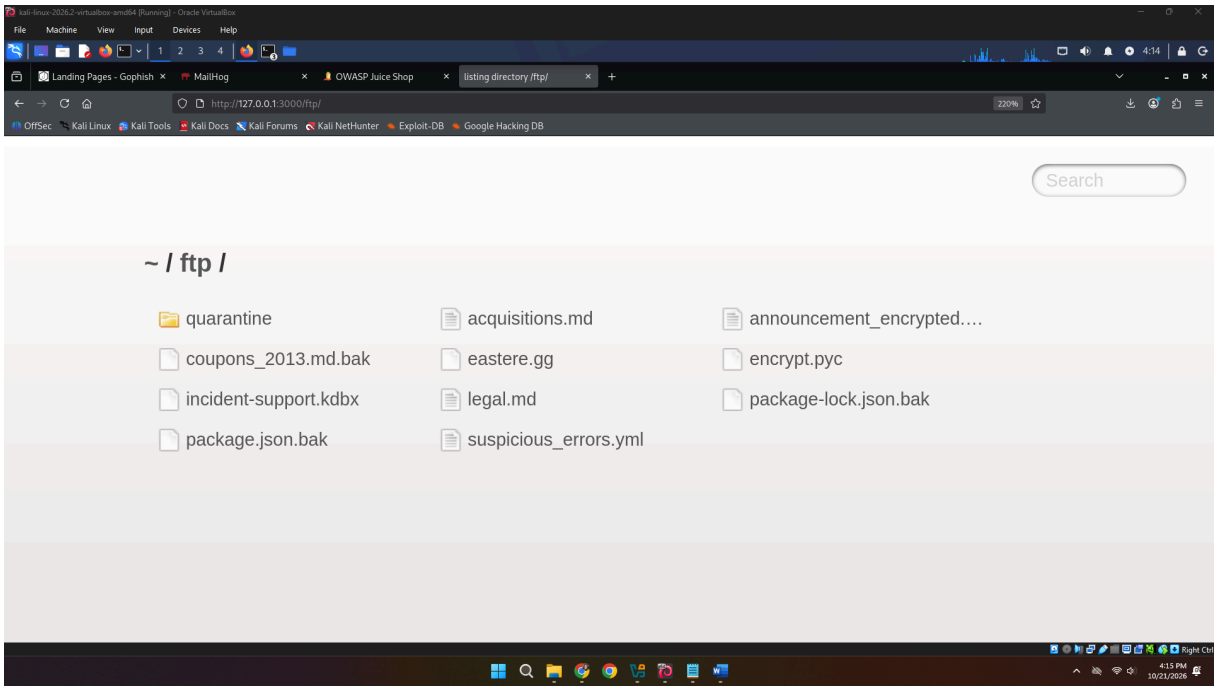
Gobuster completed 4,750 of 4,750 entries. The scan used the SecLists common wordlist, five threads, a 15-second timeout, and excluded responses with a length of 9,984 bytes.

Figure 2. Saved Gobuster output



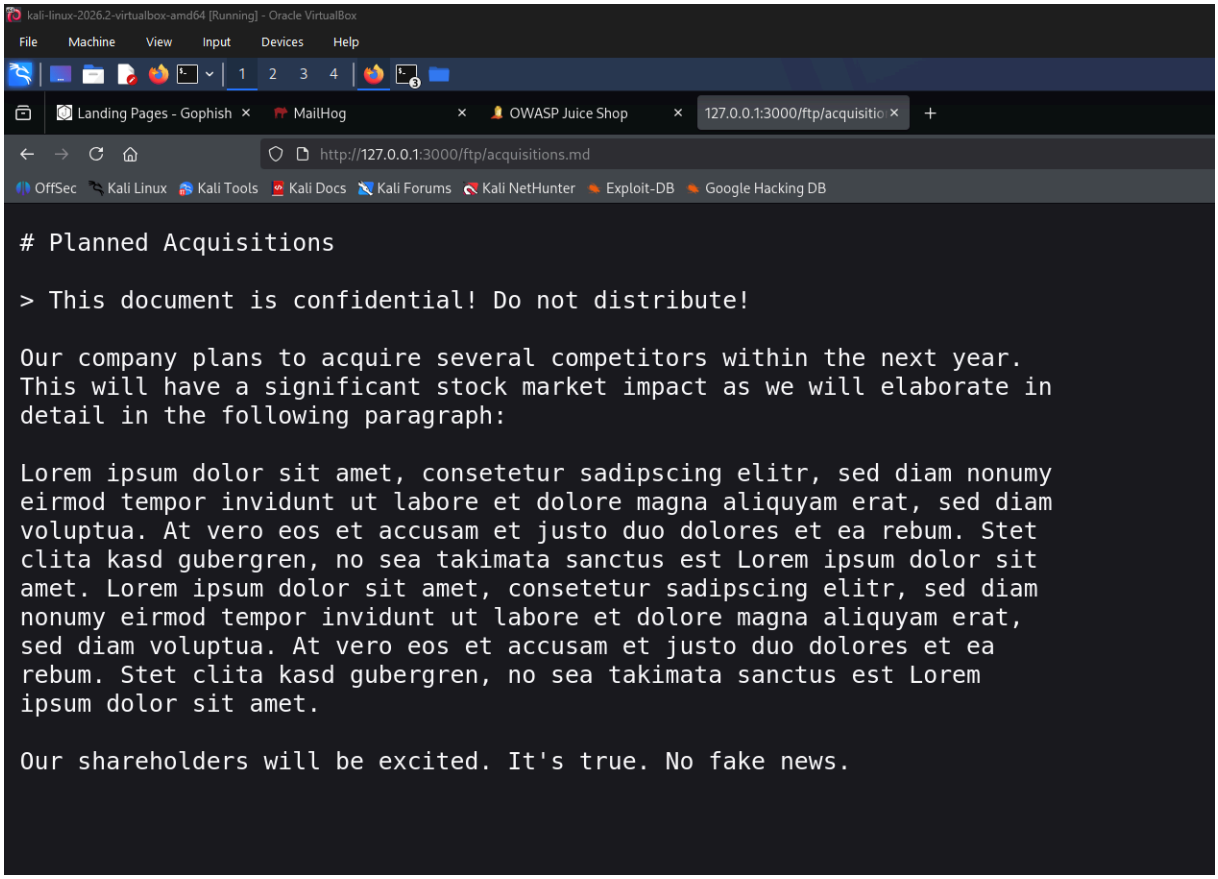
The saved output file is ~/juice-shop-gobuster-seclists.txt. The displayed results record discovered paths, HTTP status codes, and response sizes.

Figure 3. FTP directory listing



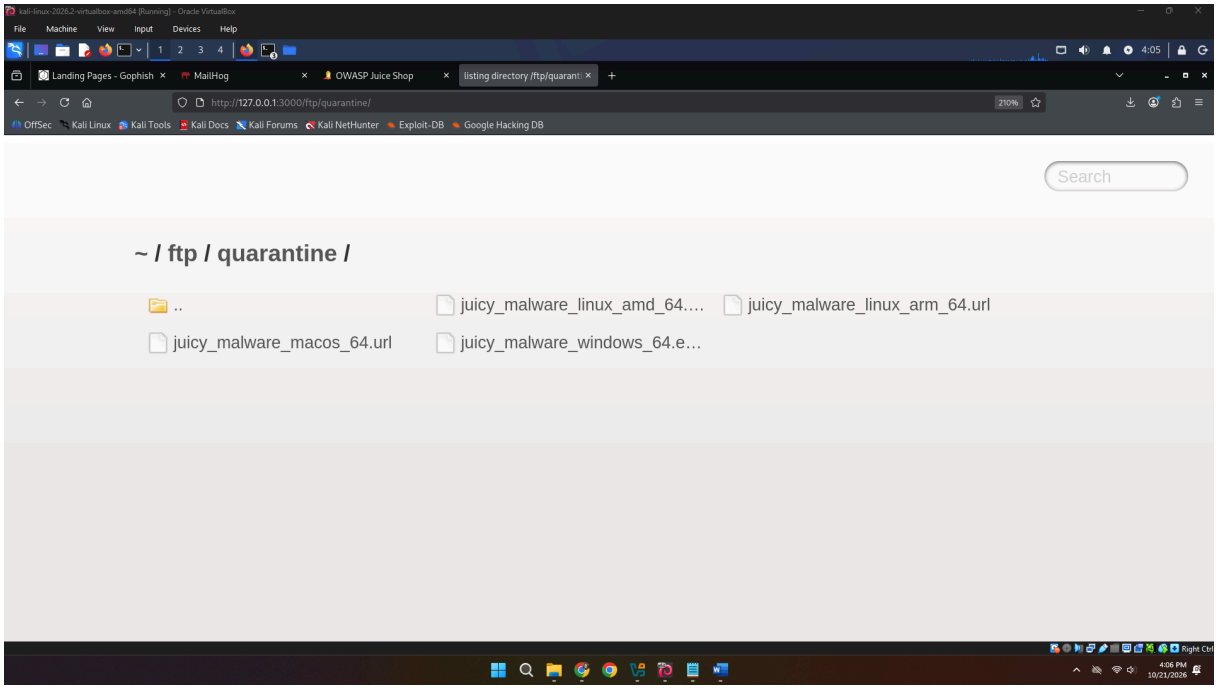
The /ftp/ directory index exposes a list of files and a quarantine subdirectory. The listing alone does not prove that every listed file can be retrieved.

Figure 4. Acquisitions document



The accessible acquisitions.md document includes a confidentiality warning. Much of its content is placeholder text, so its business claims are not treated as verified facts.

Figure 5. Quarantine listing



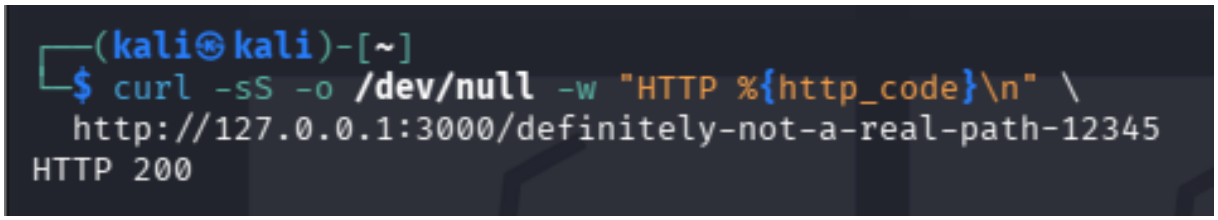
The quarantine listing includes platform-specific, malware-themed .url filenames. The files were not downloaded or executed.

Figure 6. Backup-file request blocked



The request to /ftp/package.json.bak returned HTTP 403. This demonstrates that this specific request was denied, not that all sensitive files are protected.

Figure 7. Nonexistent-looking path returns HTTP 200



The random test path returned HTTP 200. This may indicate a catch-all route or soft-404 behavior; the status code alone does not prove that the resource exists.

Figure 8. Extension restriction error response



The request to /ftp/suspicious_errors.yml returned HTTP 403 with an error stating that only .md and .pdf files are allowed.

Figure 9. Stack-trace details in error response



The response also exposes application stack-trace and file-path details. This can aid troubleshooting but should generally not be shown to unauthenticated users in production.

11. Conclusion

The lab demonstrates a repeatable workflow for enumerating web paths, saving output, manually validating selected endpoints, and communicating security observations with appropriate limitations. The clearest concerns in the supplied evidence are the public directory listing and the accessible document labeled confidential. The 403 responses show that some requests were blocked, while the HTTP 200 response for a random path and the HTTP 500 results require additional validation before stronger conclusions can be made.